

# PAYMENT INITIATION TAXONOMY AUDIT

## PART 3 – FINAL PAYMENT INITIATION TAXONOMY

### FAMILY PI-F001: GENAI-POWERED PAYMENT INSTRUCTION MANIPULATION

#### A. IDENTITY

| Field                             | Value                                                                                                                                                                                                 |
|-----------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Attack ID                         | PI-F001                                                                                                                                                                                               |
| Attack Family                     | GenAI-Powered Payment Instruction Manipulation                                                                                                                                                        |
| Attack Subtypes / Variants        | Payment redirection; Business Email Compromise (BEC) payment fraud; Invoice fraud / fake invoice scams; QR code manipulation; Beneficiary substitution; Vendor impersonation                          |
| Primary Lifecycle Stage           | Payment Initiation                                                                                                                                                                                    |
| Secondary / Cross-stage Stages    | Authentication (email compromise); Account Creation (mule accounts); AML/Cash-out (funds laundering)                                                                                                  |
| Target / Actor                    | Finance teams, accounts payable departments, businesses, individuals making payments; Payment beneficiaries; QR code payment systems                                                                  |
| Attack Objective                  | Divert legitimate payments from intended beneficiaries to attacker-controlled accounts through hyper-personalized AI-generated communications, AI-generated invoices, and multi-channel impersonation |
| Payment Rails / Channels Affected | Bank transfers; Wire transfers; B2B payments; Invoice payments; UPI; QR code payments; All payment rails                                                                                              |

#### B. FRAUD UNDERSTANDING

##### What is the attack?

Attackers use GenAI to intercept, alter, or replace legitimate payment instructions – redirecting funds from intended beneficiaries to attacker-controlled accounts. The attack employs LLM-generated hyper-personalized emails with perfect grammar and authentic tone, AI-generated counterfeit invoices with photorealistic quality, and increasingly, deepfake voice/video to validate payment requests in real time. Unlike traditional phishing-based redirection, GenAI enables contextually accurate communications that reference real projects, colleagues, and transactions – making detection by conventional email filters nearly impossible.

##### Traditional mechanism:

Before GenAI, payment redirection relied on generic phishing emails with detectable grammar errors, manual email monitoring, and opportunistic timing. Attackers manually altered invoices using Photoshop or physical forgeries. Detection was possible through grammar/spelling checks, formatting errors, and known fraud patterns. Each attack required significant human effort to craft convincing messages.

##### GenAI transformation:

| Dimension             | Pre-GenAI                           | GenAI-Transformed                                                      |
|-----------------------|-------------------------------------|------------------------------------------------------------------------|
| Communication quality | Generic, detectable errors          | Perfect grammar, authentic tone, context-aware                         |
| Personalization       | Manual, limited                     | AI-generated personalized content referencing real projects/colleagues |
| Invoice quality       | Manual Photoshop, detectable errors | AI-generated photorealistic invoices in seconds                        |
| Multi-channel         | Email only                          | Email + voice + video (deepfake)                                       |
| Scale                 | Human-limited, opportunistic        | Industrial-scale, thousands of targeted attempts                       |
| Adaptation            | Static templates                    | Real-time adaptation based on detection feedback                       |

##### Why GenAI is load-bearing:

If GenAI is removed, the attacker loses the ability to:

- Generate grammatically perfect, contextually accurate payment redirection emails at scale
- Create photorealistic counterfeit invoices without specialized graphic design skills
- Craft messages referencing specific projects, colleagues, and transaction details
- Generate deepfake voice/video to validate payment requests when challenged
- Adapt communications based on detection feedback

The attack reverts to detectable template-based phishing and manual forgeries.

**HARD GenAI Removal Test result: PASS** — GenAI creates a qualitatively new capability. The transformation from generic, detectable payment redirection to hyper-personalized, multi-channel deception at scale is a qualitative leap.

**Prerequisites:**

- Access to GenAI tools (LLMs, image generation, voice cloning)
- Target intelligence (vendor relationships, payment workflows, email patterns)
- Knowledge of target organization's payment processes
- Ability to deliver fraudulent communications (email compromise or spoofing)
- (For advanced) Voice/video deepfake capability

**Attack Flow:**

1. Attacker conducts reconnaissance on target organization/vendor relationships using OSINT and AI-powered data analysis
2. Attacker identifies pending payments, regular vendor relationships, or payment workflows
3. Attacker uses GenAI to generate personalized fraudulent communication (email, invoice, or deepfake voice/video)
4. Attacker delivers fraudulent instruction to payer (email, phone call, QR code replacement)
5. Payer believes they are paying legitimate vendor/beneficiary
6. Payer authenticates legitimately and authorizes payment
7. Payment sent to attacker-controlled beneficiary account
8. Funds immediately moved through layering to prevent recovery

**Payment Lifecycle Point: FRAUD ENTERS AT PAYMENT INITIATION** — The fraudulent payment instruction is created and submitted by the manipulated payer.

**Downstream Payment / Financial Consequence:**

- Direct financial loss to payer (businesses, individuals)
- Payment redirection scams: \$166.8M in Australia (2025)
- BEC + funds transfer fraud: 58% of all cyber insurance claims
- Average BEC incident loss: \$27,000; fraudulent instructions to banks: \$218,000
- Funds laundered through mule network; difficult to recover
- Reputational damage to businesses

C. DETECTION INTELLIGENCE

**Observable Signals:**

| Signal Category   | Specific Signals                                            | Detection Method          | Cross-account Needed? |
|-------------------|-------------------------------------------------------------|---------------------------|-----------------------|
| Transaction       | Beneficiary account change for regular vendor               | Rules + Anomaly detection | No                    |
| Transaction       | Urgent payment request / expedited processing               | Rules + Anomaly detection | No                    |
| Transaction       | Payment amount inconsistent with historical vendor payments | ML anomaly detection      | No                    |
| Transaction       | New beneficiary added shortly before payment                | Rules + Anomaly detection | No                    |
| Payer             | Unusual payment behavior (new beneficiary, urgent)          | Behavioral analytics      | No                    |
| Payee/Beneficiary | Beneficiary account flagged in mule databases               | Threat intelligence       | Yes                   |
| Payee/Beneficiary | Beneficiary has no prior relationship with payer            | Rules                     | No                    |
| Communication     | Email from known sender with unusual tone/urgency           | NLP + LLM-based detection | No                    |
| Communication     | Payment details changed via email (no verification)         | Rules + Workflow analysis | No                    |
| Communication     | Domain spoofing / lookalike domains                         | Domain reputation         | Yes                   |
| Communication     | AI-generated content patterns in emails                     | NLP analysis              | No                    |
| Network           | Beneficiary connected to known fraud rings                  | Graph analytics           | Yes                   |

| Signal Category | Specific Signals                                       | Detection Method       | Cross-account Needed? |
|-----------------|--------------------------------------------------------|------------------------|-----------------------|
| Network         | Multiple payers sending to same suspicious beneficiary | Graph Neural Network   | Yes                   |
| Network         | Same QR code pattern used across multiple locations    | QR code fingerprinting | Yes                   |
| Temporal        | Payment occurs shortly after beneficiary change        | Temporal correlation   | No                    |
| Temporal        | Off-hours payment request                              | Anomaly detection      | No                    |

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Rotate multiple mule accounts to avoid pattern detection
- Use GenAI to generate perfectly matched communication styles
- Time requests to match legitimate payment cycles
- Use deepfake voice calls to "validate" payment requests when challenged
- Vary attack patterns across targets to evade ML detection
- Use compromised legitimate accounts (not spoofed) to send fraudulent instructions

Legitimate Behavior That Could Look Similar:

| Legitimate Scenario         | Why It Looks Similar                  | False-Positive Risk                          |
|-----------------------------|---------------------------------------|----------------------------------------------|
| Vendor changes bank account | New beneficiary for regular vendor    | Blocking legitimate vendor account changes   |
| New vendor onboarding       | First-time payment to new beneficiary | Blocking legitimate new vendor payments      |
| Urgent legitimate payment   | Expedited processing, unusual timing  | Blocking legitimate urgent business payments |
| Business acquisition        | Changes in vendor relationships       | Blocking legitimate post-acquisition changes |
| Employee error              | Payment to wrong account              | False positives on legitimate mistakes       |
| Large one-time payment      | Unusual amount, new beneficiary       | Blocking legitimate large payments           |

D. SIMULATION INTELLIGENCE

| Field                          | Value                                                                                                                                                                                    |
|--------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Simulation Type                | Agentic                                                                                                                                                                                  |
| Generation Parameters          | Impersonation type; personalization level; communication channel; urgency level; payment size; invoice quality; deepfake quality                                                         |
| Synthetic Payers               | Corporate finance personas (AP clerks, CFOs, finance managers); Individual bill payers; Business owners                                                                                  |
| Synthetic Payees/Beneficiaries | Legitimate vendor personas (with historical payment data); Fraudulent substitute beneficiary accounts (mule accounts)                                                                    |
| Synthetic Merchants            | Vendor personas (suppliers, service providers, contractors)                                                                                                                              |
| Payment Rail                   | Bank transfers; Wire transfers; B2B payments; Invoice payments; UPI; QR codes                                                                                                            |
| Payment Attributes             | Amount distributions (matching vendor profiles); Urgency flags; Beneficiary details; Invoice numbers                                                                                     |
| Synthetic Transactions         | Historical legitimate payments (baseline); Beneficiary change; Fraudulent payment authorization; Fund transfer to mule account                                                           |
| Behavioral Events              | Normal payment behavior → Sudden beneficiary change → Urgent payment request → Payment authorization                                                                                     |
| Communication/Content          | LLM-generated emails mimicking specific vendor/executive communication styles; AI-generated invoices with authentic formatting; Deepfake voice validation calls; AI-generated QR codes   |
| Temporal Behavior              | Payment timing (end of month, quarter); Time between beneficiary change and payment (hours to days); Urgency patterns                                                                    |
| Network Relationships          | Payer-vendor relationship history; Beneficiary network connections; Mule account clustering                                                                                              |
| Attack Labels                  | BEC variant (vendor impersonation, executive impersonation); Invoice fraud; Payment redirection; QR code manipulation                                                                    |
| Variant / Mutation Parameters  | Communication channel (email/phone/video); Impersonation type (vendor/executive); Urgency level; Payment size; Beneficiary rotation; Communication style variation; Timing randomization |
| Legitimate Counterpart         | Legitimate vendor account changes; New vendor onboarding; Urgent business payments                                                                                                       |
| Realistic Edge Cases           | Partial success (some payments redirected, some not); Detection and recovery; Multi-stage attacks; QR code replacement detection                                                         |

E. EVIDENCE

| Claim                                                                                 | Source                    | Publisher       | Date | Evidence Type       | Confidence           |
|---------------------------------------------------------------------------------------|---------------------------|-----------------|------|---------------------|----------------------|
| 40% of BEC phishing emails are AI-generated                                           | VIPRE Q2 2024             | VIPRE           | 2024 | Industry report     | VERIFIED             |
| BEC + FTF = 58% of cyber insurance claims                                             | Coalition 2025            | Coalition       | 2025 | Industry report     | VERIFIED             |
| Social engineering FTF average loss: \$127,000                                        | Coalition 2025            | Coalition       | 2025 | Industry report     | VERIFIED             |
| Fraudulent instructions to banks average: \$218,000                                   | Coalition 2025            | Coalition       | 2025 | Industry report     | VERIFIED             |
| Payment redirection scams: \$166.8M in Australia                                      | National Anti-Scam Centre | Government      | 2025 | Government report   | VERIFIED             |
| FINRA TIP on GenAI-enhanced BEC                                                       | FINRA                     | FINRA           | 2025 | Regulatory advisory | VERIFIED             |
| Deepfake video of CFO in Zoom call for \$25M fraud                                    | Public reporting          | Media/Industry  | 2025 | Industry report     | VERIFIED             |
| German company lost €480,000 to AI-generated CEO email, voice, contract               | Public reporting          | Media/Industry  | 2025 | Industry report     | VERIFIED             |
| GenAI made phishing/BEC/invoice fraud contextually accurate and linguistically fluent | Help Net Security         | Industry        | 2025 | Industry report     | REASONABLE INFERENCE |
| 14% of fraudulent documents in Sept 2025 were AI-generated                            | AppZen                    | AppZen          | 2025 | Industry report     | VERIFIED             |
| Ramp flagged >\$1M in fraudulent invoices within 90 days                              | Ramp                      | Ramp            | 2025 | Industry report     | VERIFIED             |
| Delhi police arrested man for AI-driven QR code scam                                  | Delhi Police              | Law enforcement | 2025 | Law enforcement     | VERIFIED             |
| Over 100 tampered QR codes recovered from one attacker                                | Delhi Police              | Law enforcement | 2025 | Law enforcement     | VERIFIED             |
| Teenager arrested for AI-based QR code fraud                                          | Delhi Police              | Law enforcement | 2026 | Law enforcement     | VERIFIED             |

F. PRODUCT MAPPING

| Component          | Implementation                                                                                                                                                                                                                                                                                                                                |
|--------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Generate           | Agentic generation of payment redirection emails (LLM); Algorithmic generation of counterfeit invoices; Deepfake voice/video generation; QR code generation with altered payment details; Parameterization by impersonation type, personalization level, payment size                                                                         |
| Defend             | NLP for email/communication analysis; Document forensics for invoice authenticity; Domain reputation scoring; Beneficiary risk scoring; QR code integrity verification                                                                                                                                                                        |
| Detection Approach | Supervised ML for beneficiary risk; NLP/LLM for communication analysis; Graph Neural Network for mule network detection; Anomaly detection for behavioral deviations; Temporal correlation for beneficiary change → payment sequences                                                                                                         |
| Mitigation         | <b>Allow</b> — Low risk, known beneficiary, normal patterns; <b>Challenge</b> — Medium risk (step-up verification, call-back verification); <b>Hold</b> — High risk (delay payment pending verification); <b>Review</b> — Very high risk (manual review required); <b>Block</b> — Critical risk (known fraud pattern, confirmed mule account) |
| Evaluation         | Precision (avoiding false positives on legitimate vendor changes); Recall (catching payment redirection); False Positive Rate; Time-to-Detection                                                                                                                                                                                              |

FAMILY PI-F002: GENAI-POWERED AUTHORIZED PUSH PAYMENT (APP) FRAUD

A. IDENTITY

| Field         | Value                                             |
|---------------|---------------------------------------------------|
| Attack ID     | PI-F002                                           |
| Attack Family | GenAI-Powered Authorized Push Payment (APP) Fraud |

| Field                             | Value                                                                                                                                                                                      |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Attack Subtypes / Variants        | Investment scams; Romance scams; Impersonation scams (bank official, law enforcement, family); Digital Arrest scams; Purchase scams; Advance fee fraud; Deepfake video/voice impersonation |
| Primary Lifecycle Stage           | Payment Initiation                                                                                                                                                                         |
| Secondary / Cross-stage Stages    | Account Creation (mule accounts); AML/Cash-out (funds laundering); Authentication (victim authenticates legitimately)                                                                      |
| Target / Actor                    | Individual bank customers; Business employees; Investors; Individuals seeking relationships; General public                                                                                |
| Attack Objective                  | Manipulate legitimate users into authorizing payments to attacker-controlled accounts using GenAI-powered social engineering (deepfake video, voice cloning, LLM-generated scripts)        |
| Payment Rails / Channels Affected | Bank transfers; UPI; Wallets; Instant payments; All payment channels                                                                                                                       |

B. FRAUD UNDERSTANDING

What is the attack?

Attackers use GenAI-powered social engineering — deepfake video, voice cloning, and LLM-generated personalized scripts — to manipulate legitimate users into authorizing payments to attacker-controlled accounts. The victim willingly initiates the transaction, believing it is legitimate. Unlike traditional social engineering, GenAI enables hyper-personalized, multi-channel deception (voice, video, text) at scale, making scams nearly indistinguishable from legitimate communications. Investment scams accounted for almost half of APP losses in 2025.

Traditional mechanism:

Before GenAI, APP fraud relied on manual social engineering with generic scripts. Attackers made phone calls (human callers with scripts), sent generic phishing emails, or manually built relationships over time. Detection was possible through poor impersonation quality, generic content, and known fraud patterns. Each victim engagement required significant human effort.

GenAI transformation:

| Dimension       | Pre-GenAI                            | GenAI-Transformed                           |
|-----------------|--------------------------------------|---------------------------------------------|
| Script quality  | Generic, detectable                  | Hyper-personalized, adaptive in real time   |
| Voice           | Human impersonation, limited quality | AI voice clones indistinguishable from real |
| Video           | Pre-recorded or none                 | Real-time deepfake video impersonation      |
| Personalization | Manual, limited                      | AI-powered from OSINT and breached data     |
| Scale           | Human-limited (one caller at a time) | Automated, industrial-scale                 |
| Adaptation      | Static scripts                       | Real-time dialogue adaptation using LLMs    |

Why GenAI is load-bearing:

If GenAI is removed, the attacker loses the ability to:

- Generate convincing deepfake video impersonations in real time
- Create voice clones that sound indistinguishable from real individuals
- Hyper-personalize scams based on detailed victim profiles
- Conduct real-time adaptive conversations in any language
- Scale attacks beyond human-caller limitations
- Generate convincing fake investment platforms and websites

The attack reverts to manual social engineering with limited quality and scalability.

**HARD GenAI Removal Test result: PASS** — GenAI creates a qualitatively new capability. The transformation from generic, human-limited social engineering to hyper-personalized, multi-channel deception at scale is a qualitative leap.

Prerequisites:

- Access to GenAI tools (LLMs, voice cloning, deepfake video)
- Victim intelligence (social media, breached data)
- Communication channel (phone, email, video, messaging)
- (For deepfake) Voice/video samples (3 seconds sufficient for voice)
- (For scale) AI agent infrastructure

Attack Flow:

1. Attacker gathers intelligence on victim using AI-powered OSINT
2. Attacker generates personalized scam script using LLM (or real-time dialogue generation)
3. Attacker creates voice clone or deepfake video of trusted individual (if needed)
4. Attacker contacts victim via appropriate channel (phone, video call, email, messaging)
5. Attacker uses GenAI-generated content to create urgency/fear/trust
6. Victim logs into banking app or payment system (legitimate authentication)
7. Victim adds new beneficiary (attacker-controlled account)
8. Victim authorizes payment voluntarily (believes it is legitimate)
9. Funds transferred to attacker-controlled account
10. Funds immediately laundered through crypto wallets or mule accounts

**Payment Lifecycle Point: FRAUD ENTERS AT PRE-PAYMENT MANIPULATION** – The attacker manipulates the payer before payment creation, but the fraudulent payment instruction is created and authorized at Payment Initiation.

Downstream Payment / Financial Consequence:

- Direct financial loss to victim
- APP fraud: £576.4M lost in 2025 (UK), up 19%; 248,070 cases
- Investment scams: £221.5M (up 40%); Romance scam losses at record highs
- Digital Arrest scams: ₹120 crore lost in India (Q1 2024)
- FBI: nearly \$900M lost to AI-generated scams in 2025
- AI impersonation drove crypto scam losses to \$17B in 2025
- Funds immediately moved through layering to prevent recovery

C. DETECTION INTELLIGENCE

Observable Signals:

| Signal Category   | Specific Signals                                               | Detection Method           | Cross-account Needed? |
|-------------------|----------------------------------------------------------------|----------------------------|-----------------------|
| Transaction       | New beneficiary addition                                       | Rules + Anomaly detection  | No                    |
| Transaction       | Large transfer to new beneficiary                              | Rules + ML                 | No                    |
| Transaction       | Amount exceeds normal transaction patterns                     | ML anomaly detection       | No                    |
| Transaction       | Multiple payments to same new beneficiary                      | ML pattern detection       | No                    |
| Transaction       | Payment to accounts with no legitimate relationship            | Entity resolution          | Yes                   |
| Payer             | Unusual session behavior (hesitation, searching for functions) | Behavioral biometrics      | No                    |
| Payer             | Rapid authentication followed by unusual transaction           | Temporal correlation       | No                    |
| Payer             | Victim on phone during banking session                         | Device/call correlation    | No                    |
| Payee/Beneficiary | Beneficiary flagged in mule databases                          | Threat intelligence        | Yes                   |
| Payee/Beneficiary | Beneficiary account has no legitimate relationship with payer  | Entity resolution          | Yes                   |
| Communication     | Victim received suspicious communication before payment        | Communication intelligence | Yes                   |
| Behavioral        | Unusual navigation patterns (searching for transfer functions) | Behavioral analytics       | No                    |
| Behavioral        | Signs of distress/coercion in voice                            | Voice stress analysis      | No                    |
| Behavioral        | Unnatural interaction patterns (hesitation, repetition)        | Behavioral biometrics      | No                    |
| Network           | Beneficiary connected to known fraud/mule networks             | Graph Neural Network       | Yes                   |
| Network           | Beneficiary has no legitimate relationship with payer          | Entity resolution          | Yes                   |
| Temporal          | Payment shortly after suspicious communication                 | Temporal correlation       | Yes                   |
| Temporal          | Unusual transaction timing (off-hours, weekends)               | Rule-based + ML            | No                    |

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Normalize transactions to match victim's profile (amounts, timing, frequencies)
- Use varied beneficiary accounts with no obvious connections

- Switch communication channels to build credibility
- Improve deepfake quality to eliminate artifacts
- Target victims less likely to trigger fraud alerts (elderly, isolated)
- Adapt scripts based on victim responses using LLMs in real time

Legitimate Behavior That Could Look Similar:

| Legitimate Scenario        | Why It Looks Similar             | False-Positive Risk                            |
|----------------------------|----------------------------------|------------------------------------------------|
| Legitimate large purchase  | Large payment to new beneficiary | Blocking legitimate property/vehicle purchases |
| Legitimate investment      | Payment to investment platform   | Blocking legitimate investments                |
| Helping family/friend      | Payment to new beneficiary       | Blocking legitimate family support             |
| Legitimate bill payment    | Payment to new service provider  | Blocking legitimate bill payments              |
| Business payment           | Large payment to new vendor      | Blocking legitimate vendor payments            |
| Emergency payment          | Urgent, unusual transaction      | Blocking legitimate emergencies                |
| Shift worker/International | Off-hours transactions           | Blocking legitimate off-hours activity         |

D. SIMULATION INTELLIGENCE

| Field                          | Value                                                                                                                                                                                      |
|--------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Simulation Type                | Agentic                                                                                                                                                                                    |
| Generation Parameters          | Scam type distribution; Personalization level; Voice clone quality; Deepfake quality; Communication channel; Urgency level; Payment size; Scam duration                                    |
| Synthetic Payers               | Victim personas (demographics, banking behavior, digital literacy, vulnerability profiles); KYC-verified customers                                                                         |
| Synthetic Payees/Beneficiaries | Attacker-controlled accounts (mule accounts, fake investment platforms, fake romance personas)                                                                                             |
| Synthetic Merchants            | Fake investment platforms; Fake e-commerce stores; Fake service providers                                                                                                                  |
| Payment Rail                   | Bank transfers; UPI; Wallets; Instant payments                                                                                                                                             |
| Payment Attributes             | Amount distributions (large for investments, repeated small for romance); Urgency flags; Beneficiary details                                                                               |
| Synthetic Transactions         | Historical legitimate payments (baseline); New beneficiary addition; Fraudulent payment authorization; Fund transfer to mule account; Multiple payments over time (romance scams)          |
| Behavioral Events              | Normal behavior → Contact from attacker → Unusual navigation/hesitation → New beneficiary addition → Urgent payment authorization                                                          |
| Communication/Content          | LLM-generated scam scripts; Deepfake video content; Voice clone audio; Personalized phishing messages; Fake investment platforms                                                           |
| Temporal Behavior              | Scam duration (hours for digital arrest; weeks/months for romance/investment); Payment timing; Urgency patterns; Time between communication and payment                                    |
| Network Relationships          | Attacker-victim communication patterns; Mule account clustering; Fraud ring connections                                                                                                    |
| Attack Labels                  | Investment scam; Romance scam; Impersonation scam; Digital arrest scam; Purchase scam; Advance fee fraud                                                                                   |
| Variant / Mutation Parameters  | Scam type; Communication channel; Personalization level; Deepfake quality; Urgency level; Payment size; Scam duration; Victim targeting variation; Script adaptation; Beneficiary rotation |
| Legitimate Counterpart         | Legitimate investments; Family support payments; Bill payments; Emergency payments; Business payments                                                                                      |
| Realistic Edge Cases           | Partial scams (victim resists, pays less); Multi-channel attacks; Long-duration romance scams; Detection and recovery                                                                      |

E. EVIDENCE

| Claim                                                    | Source     | Publisher  | Date | Evidence Type   | Confidence |
|----------------------------------------------------------|------------|------------|------|-----------------|------------|
| APP fraud: £576.4M lost in 2025, up 19%                  | UK Finance | UK Finance | 2026 | Industry report | VERIFIED   |
| 248,070 APP cases recorded in 2025                       | UK Finance | UK Finance | 2026 | Industry report | VERIFIED   |
| Investment scams: £221.5M losses, up 40%                 | UK Finance | UK Finance | 2026 | Industry report | VERIFIED   |
| Purchase scams: 71% of APP cases                         | UK Finance | UK Finance | 2026 | Industry report | VERIFIED   |
| Advance fee fraud: cases up 38%, losses up 65% to £58.4M | UK Finance | UK Finance | 2026 | Industry report | VERIFIED   |

| Claim                                                                                              | Source              | Publisher       | Date | Evidence Type       | Confidence |
|----------------------------------------------------------------------------------------------------|---------------------|-----------------|------|---------------------|------------|
| Romance scam losses at record highs                                                                | UK Finance          | UK Finance      | 2026 | Industry report     | VERIFIED   |
| "Digital Arrest" scams: ₹120 crore lost in India (Q1 2024)                                         | Government of India | Government      | 2024 | Government report   | VERIFIED   |
| 68-year-old lost ₹1.5 crore to digital arrest scam with AI-generated visuals                       | Public reporting    | Media           | 2025 | Industry report     | VERIFIED   |
| Retired army officer lost ₹78 lakh to digital arrest scam with AI-generated voices/video           | Public reporting    | Media           | 2025 | Industry report     | VERIFIED   |
| AI impersonation drove crypto scam losses to \$17B in 2025                                         | Chainalysis         | Chainalysis     | 2026 | Industry report     | VERIFIED   |
| FBI: nearly \$900M lost to AI-generated scams in 2025                                              | FBI                 | FBI             | 2025 | Government advisory | VERIFIED   |
| AI-powered deepfakes make APP fraud "infinitely easier to perpetrate"                              | UK Finance          | UK Finance      | 2026 | Industry report     | VERIFIED   |
| FATF: APP fraud estimated >\$330B by 2027                                                          | FATF                | FATF            | 2025 | Government report   | VERIFIED   |
| GenAI has permanently altered fraud landscape; criminals exploit AI to industrialize operations    | FATF                | FATF            | 2025 | Government report   | VERIFIED   |
| Six arrested for AI-powered investment scam stealing €19M from 208 victims                         | Public reporting    | Media           | 2025 | Industry report     | VERIFIED   |
| Deepfake ring in Hong Kong busted for \$4.37M romance/investment scams                             | Public reporting    | Media           | 2025 | Industry report     | VERIFIED   |
| AI-generated deepfake ads featuring popular public figures for investment scams                    | Public reporting    | Media           | 2025 | Industry report     | VERIFIED   |
| Bitcoin investor lost retirement to AI deepfake romance scam                                       | Public reporting    | Media           | 2025 | Industry report     | VERIFIED   |
| Digital arrest threats among most common scams in 2025                                             | CERT-In             | CERT-In         | 2025 | Government advisory | VERIFIED   |
| Uttarakhand: 10,300 cybercrime cases in 2025, including digital arrest scams with AI voice cloning | Uttarakhand Police  | Law enforcement | 2025 | Law enforcement     | VERIFIED   |
| Fraudsters use AI chat generators to create official-looking emails                                | FBI IC3             | FBI             | 2025 | Government advisory | VERIFIED   |

F. PRODUCT MAPPING

| Component          | Implementation                                                                                                                                                                                                                                                                                                                                           |
|--------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Generate           | Agentic generation of scam scenarios, dialogue, and messages; Voice clone generation; Deepfake video generation; Algorithmic generation of transaction sequences; Synthetic persona generation for victims and attackers                                                                                                                                 |
| Defend             | Behavioral analytics for transaction anomalies; Graph analytics for beneficiary network analysis; Behavioral biometrics for coercion detection; Voice stress analysis; Real-time anomaly detection; Communication intelligence                                                                                                                           |
| Detection Approach | Behavioral anomaly detection; Graph Neural Network for beneficiary risk scoring; Temporal correlation for communication → payment sequences; NLP for communication analysis; Voice stress analysis for coercion detection                                                                                                                                |
| Mitigation         | <b>Allow</b> — Low risk, known beneficiary, normal patterns; <b>Challenge</b> — Medium risk (step-up verification, confirmation questions); <b>Hold</b> — High risk (delay payment, customer education notification); <b>Review</b> — Very high risk (manual review, call-back verification); <b>Block</b> — Critical risk (confirmed fraud, known mule) |
| Evaluation         | Precision (avoiding false positives on legitimate transactions); Recall (catching APP fraud); False Positive Rate; Time-to-Detection; Detection before payment vs. after payment                                                                                                                                                                         |

FAMILY PI-F003: GENAI-POWERED REFUND / POLICY ABUSE

A. IDENTITY

| Field         | Value                               |
|---------------|-------------------------------------|
| Attack ID     | PI-F003                             |
| Attack Family | GenAI-Powered Refund / Policy Abuse |



| Field                             | Value                                                                                                                      |
|-----------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Attack Subtypes / Variants        | AI-generated fake damage images; AI-generated fake damage videos; Wardrobing (wearing and returning); Receipt manipulation |
| Primary Lifecycle Stage           | Payment Initiation (Refund/Credit reversal)                                                                                |
| Secondary / Cross-stage Stages    | Dispute/Chargeback; Merchant fraud                                                                                         |
| Target / Actor                    | E-commerce merchants; Online retailers; Payment platforms; Consumers (through higher prices)                               |
| Attack Objective                  | Obtain refunds without returning products using AI-generated evidence of damage, defects, or non-delivery                  |
| Payment Rails / Channels Affected | Card payments; E-commerce; Wallets; BNPL; Refund/reversal mechanisms                                                       |

B. FRAUD UNDERSTANDING

What is the attack?

Attackers use AI-generated images and videos to fabricate evidence of product damage, defects, or non-delivery – enabling fraudulent refund claims where customers keep the goods and receive refunds. AI-generated images are "indistinguishable from real structural defects," making it nearly impossible for merchants to distinguish legitimate from fraudulent claims. Organized crime groups are using tools to automate fraud at scale.

Traditional mechanism:

Before GenAI, refund fraud required physical damage to products, crude Photoshop forgeries, or exploiting policy loopholes (e.g., wardrobing). Detection was possible through formatting errors in forged images, lack of consistent evidence, and manual review of return patterns. Each fraudulent claim required significant effort.

GenAI transformation:

| Dimension         | Pre-GenAI                        | GenAI-Transformed                               |
|-------------------|----------------------------------|-------------------------------------------------|
| Evidence quality  | Crude forgeries, physical damage | AI-generated photorealistic images/videos       |
| Scale             | Manual, limited                  | AI tools enable automated fraud at scale        |
| Democratization   | Required skills/equipment        | Tutorials sold online; low technical barrier    |
| Detection evasion | Detectable artifacts             | Increasingly indistinguishable from real damage |

Why GenAI is load-bearing:

If GenAI is removed, the attacker loses the ability to:

- Generate photorealistic fake damage images without physical道具
- Create convincing evidence at scale for multiple claims
- Evade image-based fraud detection systems
- Generate images that are "indistinguishable from real structural defects"

The attack reverts to physically damaging products (traceable) or crude forgeries (detectable).

**HARD GenAI Removal Test result: PASS** — GenAI creates a qualitatively new capability. The transformation from crude forgeries to photorealistic fake evidence at scale is a qualitative leap.

Prerequisites:

- Access to GenAI image/video generation tools
- Product purchase (to generate refund claim)
- Understanding of merchant refund policies
- Ability to submit refund claims (existing customer account)

Attack Flow:

1. Attacker purchases product from merchant
2. Attacker uses GenAI to generate fake damage images/videos
3. Attacker submits refund claim with AI-generated evidence
4. Refund claim appears legitimate; images difficult to distinguish from real damage
5. Refund authorized; funds returned to attacker
6. Attacker keeps product and receives refund

**Payment Lifecycle Point: FRAUD ENTERS AT PAYMENT INITIATION (REFUND)** – The refund instruction is created and submitted with fraudulent evidence.

**Downstream Payment / Financial Consequence:**

- Direct loss to merchant (product cost + refund + shipping)
- 15% spike in AI-doctored refund claims globally
- Refund/policy abuse remains top fraud threat (45% of merchants)
- Organized crime rings automating fraud at scale
- Stricter return policies for legitimate customers
- Higher prices for all consumers

**C. DETECTION INTELLIGENCE**

**Observable Signals:**

| Signal Category | Specific Signals                                                   | Detection Method               | Cross-account Needed? |
|-----------------|--------------------------------------------------------------------|--------------------------------|-----------------------|
| Transaction     | High refund rate for specific customer                             | Rules + ML                     | No                    |
| Transaction     | Refund claim shortly after delivery                                | Rules                          | No                    |
| Transaction     | Repeated refunds across multiple merchants                         | Cross-merchant intelligence    | Yes                   |
| Evidence        | AI-generated image artifacts (pixel anomalies, unnatural textures) | CNN/Transformer image analysis | No                    |
| Evidence        | Inconsistent product features in images                            | ML + Rule-based                | No                    |
| Evidence        | Metadata anomalies in submitted images                             | Metadata analysis              | No                    |
| Evidence        | Same artifact patterns across multiple claims                      | Image fingerprinting           | Yes                   |
| Behavioral      | Customer submits only photos (no physical return)                  | Rules                          | No                    |
| Network         | Same IP/device used for multiple refund claims                     | Graph analytics                | Yes                   |
| Network         | Same image artifact patterns across accounts                       | Image fingerprinting           | Yes                   |
| Temporal        | Unusual refund timing                                              | Anomaly detection              | No                    |

**Evasion Considerations (Defensive Threat Modeling):**

An adaptive attacker might attempt to:

- Generate increasingly realistic images with realistic noise and artifacts
- Use different GenAI tools/patterns across claims to avoid fingerprinting
- Make legitimate purchases occasionally to build positive history
- Distribute claims across accounts to avoid velocity flags
- Combine AI-generated evidence with partial physical damage

**Legitimate Behavior That Could Look Similar:**

| Legitimate Scenario         | Why It Looks Similar                 | False-Positive Risk                                        |
|-----------------------------|--------------------------------------|------------------------------------------------------------|
| Genuine product damage      | Customer submits damage photos       | Blocking legitimate refund claims                          |
| Poor product quality        | Customer returns damaged goods       | Blocking legitimate quality complaints                     |
| Shipping damage             | Customer claims item arrived damaged | Blocking legitimate shipping damage claims                 |
| Low-quality photos          | Images may appear unusual            | False positives on legitimate claims with poor photography |
| Legitimate high return rate | Customer buys/returns frequently     | Blocking legitimate high-volume shoppers                   |

**D. SIMULATION INTELLIGENCE**

| Field                          | Value                                                                                       |
|--------------------------------|---------------------------------------------------------------------------------------------|
| Simulation Type                | Algorithmic                                                                                 |
| Generation Parameters          | Product category; Damage type; Image quality; Refund amount; Merchant type; Timing patterns |
| Synthetic Payers               | Customer personas (purchase history, refund history, behavior patterns)                     |
| Synthetic Payees/Beneficiaries | Original payer receiving refund                                                             |

| Field                         | Value                                                                                                                      |
|-------------------------------|----------------------------------------------------------------------------------------------------------------------------|
| Synthetic Merchants           | E-commerce merchants (product categories, refund policies, fraud history)                                                  |
| Payment Rail                  | Card payments; E-commerce refunds; Wallet refunds                                                                          |
| Payment Attributes            | Refund amounts; Product categories; Purchase-to-refund timing                                                              |
| Synthetic Transactions        | Purchase → Delivery → AI-generated fake damage evidence → Refund claim → Refund processed                                  |
| Behavioral Events             | Normal purchase → Suspicious refund claim with AI-generated evidence                                                       |
| Network Relationships         | Customer-merchant relationships; Refund patterns; Organized fraud rings                                                    |
| Temporal Behavior             | Purchase-to-refund timing; Refund frequency; Seasonal patterns                                                             |
| GenAI-Generated Content       | AI-generated damage images (cracked screens, torn items, spoiled food, broken electronics); AI-generated damage videos     |
| Attack Labels                 | Refund fraud; Return abuse; Policy abuse; Wardrobing                                                                       |
| Variant / Mutation Parameters | Product category; Damage type; Image quality; Refund amount; Merchant type; Image artifact variation; Timing randomization |
| Legitimate Counterpart        | Genuine product damage claims; Legitimate returns; Shipping damage claims                                                  |
| Realistic Edge Cases          | Partial fraud (some genuine damage, some fabricated); Mixed claims; Dispute escalation                                     |

E. EVIDENCE

| Claim                                                                                       | Source            | Publisher               | Date | Evidence Type   | Confidence           |
|---------------------------------------------------------------------------------------------|-------------------|-------------------------|------|-----------------|----------------------|
| 15% spike in AI-doctored refund claims globally                                             | Industry analysis | Fraud/security industry | 2025 | Industry report | REASONABLE INFERENCE |
| AI-generated images "indistinguishable from real structural defects"                        | Industry analysis | Fraud/security industry | 2025 | Industry report | REASONABLE INFERENCE |
| AI-generated damage photos driving sharp rise in fraudulent refund claims across e-commerce | Industry analysis | Fraud/security industry | 2025 | Industry report | REASONABLE INFERENCE |
| Organized crime groups using tools to automate fraud at scale                               | Industry analysis | Fraud/security industry | 2025 | Industry report | REASONABLE INFERENCE |
| Refund abuse remains top fraud threat (45% of merchants)                                    | MRC               | Merchant Risk Council   | 2025 | Industry report | VERIFIED             |
| Consumers using AI tools to create fake damage photos for refunds                           | Public reporting  | Media                   | 2025 | Industry report | REASONABLE INFERENCE |
| AI-generated images used to fake product damage                                             | Public reporting  | Media                   | 2025 | Industry report | REASONABLE INFERENCE |
| Tutorials for "30 successful refunds per account" sold online                               | Industry analysis | Fraud/security industry | 2025 | Industry report | REASONABLE INFERENCE |

F. PRODUCT MAPPING

| Component          | Implementation                                                                                                                                                                                                                                                |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Generate           | Algorithmic generation of AI-generated damage images with varying quality levels; Parameterization by product category, damage type, image quality; Refund claim sequences                                                                                    |
| Defend             | CNN/Transformer for image forgery detection; Anomaly detection for refund patterns; Graph analytics for cross-account pattern detection; Metadata analysis for image provenance                                                                               |
| Detection Approach | CNN/Transformer for image authenticity scoring; Anomaly detection for refund behavior; Graph analytics for organized fraud detection; Rules for refund velocity                                                                                               |
| Mitigation         | <b>Allow</b> — Low risk, genuine images, normal pattern; <b>Challenge</b> — Medium risk (request additional evidence, video verification); <b>Hold</b> — High risk (delay refund, manual review); <b>Block</b> — Confirmed fraud (deny claim, account review) |
| Evaluation         | Precision (avoiding false positives on legitimate refund claims); Recall (catching AI-generated fake evidence); False Positive Rate; Time-to-Detection                                                                                                        |

A. IDENTITY

| Field                             | Value                                                                                                                                                                                                                                         |
|-----------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Attack ID                         | PI-F004                                                                                                                                                                                                                                       |
| Attack Family                     | GenAI-Powered Synthetic Merchant Fraud                                                                                                                                                                                                        |
| Attack Subtypes / Variants        | Synthetic merchant storefronts; Fake merchant onboarding; AI-generated merchant websites; Merchant collusion; Synthetic merchant with fabricated compliance docs                                                                              |
| Primary Lifecycle Stage           | Payment Initiation                                                                                                                                                                                                                            |
| Secondary / Cross-stage Stages    | Account Creation (merchant onboarding); KYC (synthetic identity); AML/Cash-out (funds movement)                                                                                                                                               |
| Target / Actor                    | Payment networks; Acquiring banks; E-commerce platforms; Consumers; AI shopping agents                                                                                                                                                        |
| Attack Objective                  | Create fake merchant accounts using GenAI-generated storefronts with professional branding, fabricated compliance documents, and automated payment flows – enabling fraudulent transactions at scale under the guise of legitimate businesses |
| Payment Rails / Channels Affected | Card payments; Wallets; BNPL; E-commerce; All merchant payment channels                                                                                                                                                                       |

B. FRAUD UNDERSTANDING

What is the attack?

Attackers use GenAI to create convincing synthetic merchant storefronts with professional branding, fabricated compliance documents, AI-generated "team" pages, product galleries with five-star testimonials, and automated payment flows – enabling fraudulent transactions at scale under the guise of legitimate businesses. Visa reports that fraudsters "create synthetic merchant sites with professional compliance docs and credible web presences, using AI to generate every element from branding to transaction flows."

Traditional mechanism:

Before GenAI, creating a convincing fake merchant required significant time, design skills, and manual effort. Attackers used stolen identities to create merchant accounts, manual website design, and simple fraud patterns. Detection was possible through inconsistent business details, lack of physical presence, and basic compliance checks.

GenAI transformation:

| Dimension        | Pre-GenAI                     | GenAI-Transformed                                     |
|------------------|-------------------------------|-------------------------------------------------------|
| Website creation | Manual design, time-intensive | AI-generated storefronts in minutes                   |
| Branding         | Generic, detectable           | AI-generated images of non-existent owners and stores |
| Compliance docs  | Simple forgeries              | Fabricated compliance docs that routinely pass checks |
| Scale            | Limited, manual               | Industrial-scale synthetic merchant creation          |
| Credibility      | Low, detectable               | Professional-grade, indistinguishable from legitimate |

Why GenAI is load-bearing:

If GenAI is removed, the attacker loses the ability to:

- Generate professional-grade fake merchant websites in minutes
- Create AI-generated images of non-existent owners and physical stores
- Fabricate compliance documents that pass checks
- Generate convincing product galleries and reviews
- Scale synthetic merchant creation beyond manual capabilities

The attack reverts to detectable, low-quality fake merchants.

**HARD GenAI Removal Test result: PASS** – GenAI creates a qualitatively new capability. The transformation from manual, detectable fake merchants to AI-generated professional-grade synthetic merchants is a qualitative leap.

Prerequisites:

- Access to GenAI tools (LLMs, image generation, document generation)

- Ability to create merchant accounts
- Understanding of merchant onboarding requirements
- (For scale) Synthetic identities
- Payment network access

Attack Flow:

1. Attacker uses GenAI to generate synthetic merchant website, branding, product listings, compliance documents, and reviews
2. Attacker submits synthetic merchant for onboarding with fabricated compliance documents
3. Merchant passes compliance checks (documents appear legitimate)
4. Consumers (or AI shopping agents) make purchases from fake merchant
5. Payments processed through payment network; merchant receives funds
6. Goods never delivered (or cheap substitutes delivered)
7. Merchant account cashes out; chargebacks eventually follow

**Payment Lifecycle Point: FRAUD ENTERS AT MERCHANT ONBOARDING (PRE-PAYMENT)** – The fraudulent merchant is created before payment initiation, but the fraud manifests in payment processing through the fake merchant.

Downstream Payment / Financial Consequence:

- Consumers lose money for undelivered goods
- Payment networks incur chargebacks
- \$442B lost to online scams globally in 2025
- Synthetic merchant sites with professional docs routinely pass compliance checks
- Visa: fraudsters "steer conversations toward approval" using GenAI tools
- 450% surge in dark-web posts discussing "AI Agent" tools for merchant fraud

C. DETECTION INTELLIGENCE

Observable Signals:

| Signal Category | Specific Signals                                      | Detection Method               | Cross-account Needed? |
|-----------------|-------------------------------------------------------|--------------------------------|-----------------------|
| Merchant        | AI-generated website images (too perfect, artifacts)  | CNN/Transformer image analysis | No                    |
| Merchant        | Inconsistent business details (address, registration) | Entity resolution              | No                    |
| Merchant        | No physical presence / PO box address                 | Rules + External verification  | No                    |
| Merchant        | Rapid merchant account creation (velocity)            | Velocity rules                 | Yes                   |
| Merchant        | Fabricated compliance documents                       | Document forensics             | No                    |
| Merchant        | AI-generated reviews/testimonials                     | NLP analysis                   | No                    |
| Transaction     | High chargeback rate                                  | Rules + ML                     | No                    |
| Transaction     | Unusual transaction patterns                          | ML anomaly detection           | No                    |
| Transaction     | High refund rate                                      | Rules + ML                     | No                    |
| Network         | Same IP/device used for multiple merchant accounts    | Graph analytics                | Yes                   |
| Network         | Synthetic merchant connected to synthetic identities  | Graph Neural Network           | Yes                   |
| Network         | Multiple merchants with similar AI-generated patterns | Clustering                     | Yes                   |
| Temporal        | Rapid merchant approval → high transaction volume     | Velocity rules                 | No                    |

Evasion Considerations (Defensive Threat Modeling):

An adaptive attacker might attempt to:

- Use increasingly sophisticated AI to eliminate image artifacts
- Create fake storefront addresses and Google Maps listings
- Generate increasingly convincing compliance documents
- Connect synthetic merchants to synthetic consumer identities for "legitimate" transaction histories
- Build merchant reputation slowly to avoid velocity flags
- Target AI shopping agents that make automated purchasing decisions

Legitimate Behavior That Could Look Similar:

| Legitimate Scenario                         | Why It Looks Similar                       | False-Positive Risk                            |
|---------------------------------------------|--------------------------------------------|------------------------------------------------|
| New legitimate e-commerce business          | New merchant, new website                  | Blocking legitimate new businesses             |
| Home-based business                         | May have PO box, limited physical presence | Blocking legitimate small businesses           |
| Small business with limited online presence | May look "too new"                         | Blocking legitimate startups                   |
| Professional photography                    | "Too perfect" images                       | False positives on professional product photos |
| Legitimate high-volume merchant             | High transaction volume                    | Blocking legitimate successful merchants       |

D. SIMULATION INTELLIGENCE

| Field                          | Value                                                                                                                                                                              |
|--------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Simulation Type                | Hybrid (Agentic + Algorithmic)                                                                                                                                                     |
| Generation Parameters          | Merchant type; Product category; Website quality; Compliance document quality; Transaction volume; Image quality                                                                   |
| Synthetic Payers               | Consumer personas (legitimate shoppers, AI shopping agents)                                                                                                                        |
| Synthetic Payees/Beneficiaries | Synthetic merchant accounts (attacker-controlled)                                                                                                                                  |
| Synthetic Merchants            | AI-generated merchant profiles (business name, address, website, branding, product listings, team pages, reviews, compliance documents)                                            |
| Payment Rail                   | Card payments; Wallets; BNPL; E-commerce                                                                                                                                           |
| Payment Attributes             | Purchase amounts; Product categories; Merchant category codes                                                                                                                      |
| Synthetic Transactions         | Synthetic merchant creation → Merchant onboarding → Consumer purchases → Payments processed → Funds to attacker → Chargebacks (eventually)                                         |
| Behavioral Events              | Normal consumer behavior → Purchases from synthetic merchant → Non-delivery → Disputes                                                                                             |
| Network Relationships          | Synthetic merchant-identity connections; Consumer-merchant relationships; Fraud ecosystem clustering                                                                               |
| Temporal Behavior              | Merchant creation timing; Transaction ramp-up; Chargeback timing; Bust-out patterns                                                                                                |
| GenAI-Generated Content        | AI-generated merchant websites; AI-generated product images/descriptions; AI-generated team photos; AI-generated reviews; AI-generated compliance documents; AI-generated branding |
| Attack Labels                  | Synthetic merchant fraud; Merchant collusion; Fake storefront; Scam merchant                                                                                                       |
| Variant / Mutation Parameters  | Merchant type; Product category; Website quality; Compliance document quality; Transaction volume; Merchant identity variation; Website design variation                           |
| Legitimate Counterpart         | Legitimate new e-commerce businesses; Small/home-based businesses; Legitimate high-volume merchants                                                                                |
| Realistic Edge Cases           | Mixed legitimate/fraudulent merchant activity; Merchant identity theft; Synthetic merchant used for money laundering                                                               |

E. EVIDENCE

| Claim                                                                                                                                                                                | Source            | Publisher               | Date | Evidence Type   | Confidence           |
|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------|-------------------------|------|-----------------|----------------------|
| Visa: fraudsters create synthetic merchant sites with professional compliance docs and credible web presences, using AI to generate every element from branding to transaction flows | Visa              | Visa                    | 2025 | Industry report | VERIFIED             |
| GenAI deployed to mass-produce synthetic consumer identities for illicit merchant accounts                                                                                           | Visa              | Visa                    | 2025 | Industry report | VERIFIED             |
| AI-generated images of non-existent owners and physical stores                                                                                                                       | Visa              | Visa                    | 2025 | Industry report | VERIFIED             |
| AI-generated compliance docs that routinely pass checks                                                                                                                              | Visa              | Visa                    | 2025 | Industry report | VERIFIED             |
| >450% surge in dark-web posts discussing "AI Agent" tools                                                                                                                            | Visa              | Visa                    | 2025 | Industry report | VERIFIED             |
| \$442B lost to online scams globally in 2025                                                                                                                                         | Industry analysis | Fraud/security industry | 2025 | Industry report | REASONABLE INFERENCE |

| Claim                                                                                 | Source            | Publisher               | Date | Evidence Type   | Confidence                  |
|---------------------------------------------------------------------------------------|-------------------|-------------------------|------|-----------------|-----------------------------|
| Fraudsters pose as merchants and consumers working together to defraud BNPL companies | Industry analysis | Fraud/security industry | 2025 | Industry report | <b>REASONABLE INFERENCE</b> |
| AI models trained to steer conversations toward approval                              | Visa              | Visa                    | 2025 | Industry report | <b>VERIFIED</b>             |
| Fabricated compliance docs that routinely pass checks                                 | Visa              | Visa                    | 2025 | Industry report | <b>VERIFIED</b>             |

F. PRODUCT MAPPING

| Component          | Implementation                                                                                                                                                                                                                                                                  |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Generate           | Agentic generation of synthetic merchant profiles, websites, and branding; Algorithmic generation of compliance documents, transaction sequences, and network relationships                                                                                                     |
| Defend             | CNN/Transformer for image authenticity; Document forensics for compliance verification; Graph Neural Network for merchant-identity network analysis; Anomaly detection for merchant behavior; NLP for review/testimonial authenticity                                           |
| Detection Approach | Image authenticity scoring; Document forensics; Graph analytics for network connections; Anomaly detection for merchant behavior; Rules for merchant creation velocity                                                                                                          |
| Mitigation         | <b>Allow</b> — Verified legitimate merchant, normal patterns; <b>Challenge</b> — Medium risk (additional verification, enhanced monitoring); <b>Hold</b> — High risk (delay onboarding, manual review); <b>Block</b> — Confirmed fraud (reject onboarding, account termination) |
| Evaluation         | Precision (avoiding false positives on legitimate new businesses); Recall (catching synthetic merchants); False Positive Rate; Time-to-Detection                                                                                                                                |

# PART 4 – FINAL COVERAGE AUDIT

| Payment Initiation Attack Surface   | Considered?                  | Covered By       | Separate Family? | Reason                                   |
|-------------------------------------|------------------------------|------------------|------------------|------------------------------------------|
| Payment creation                    | ✓                            | PI-F001, PI-F002 | No               | Covered by manipulation and APP families |
| Payment instruction manipulation    | ✓                            | PI-F001          | Yes              | Distinct family                          |
| Payment amount manipulation         | ✓                            | PI-F001          | No               | Variant of instruction manipulation      |
| Beneficiary/payee manipulation      | ✓                            | PI-F001          | No               | Variant of instruction manipulation      |
| Merchant manipulation               | ✓                            | PI-F004          | Yes              | Distinct family — synthetic merchants    |
| Fraudulent payment requests         | ✓                            | PI-F002          | No               | Covered by APP fraud                     |
| Authorized push payment fraud       | ✓                            | PI-F002          | Yes              | Distinct family                          |
| Social-engineering-induced payments | ✓                            | PI-F002          | No               | Covered by APP fraud                     |
| Impersonation-driven payment fraud  | ✓                            | PI-F002          | No               | Covered by APP fraud                     |
| Invoice/payment redirection         | ✓                            | PI-F001          | No               | Covered by instruction manipulation      |
| BEC-related payment fraud           | ✓                            | PI-F001          | No               | Covered by instruction manipulation      |
| Investment/payment scams            | ✓                            | PI-F002          | No               | Covered by APP fraud                     |
| Romance/payment scams               | ✓                            | PI-F002          | No               | Covered by APP fraud                     |
| Payment credential misuse           | <b>MOVE → Authentication</b> | —                | —                | Primary attack is credential theft       |
| Card-not-present fraud              | <b>DROP</b>                  | —                | —                | GenAI amplification, not transformation  |
| Transaction testing                 | <b>DROP</b>                  | —                | —                | GenAI amplification, not transformation  |
| Transaction enumeration             | <b>DROP</b>                  | —                | —                | GenAI amplification, not transformation  |
| Repeated authorization attempts     | <b>DROP</b>                  | —                | —                | GenAI amplification, not transformation  |
| Duplicate payment abuse             | <b>DROP</b>                  | —                | —                | No GenAI load-bearing role               |
| Payment replay                      | <b>DROP</b>                  | —                | —                | No GenAI load-bearing role               |

| Payment Initiation Attack Surface           | Considered? | Covered By                | Separate Family? | Reason                                             |
|---------------------------------------------|-------------|---------------------------|------------------|----------------------------------------------------|
| Payment velocity abuse                      | <b>DROP</b> | —                         | —                | GenAI amplification; overlaps with AML/structuring |
| New beneficiary fraud                       | ✓           | PI-F001, PI-F002          | No               | Covered by both families                           |
| P2P payment fraud                           | ✓           | PI-F002                   | No               | Covered by APP fraud                               |
| Instant-payment abuse                       | <b>DROP</b> | —                         | —                | GenAI amplification; rail-specific                 |
| Wallet payment abuse                        | ✓           | PI-F001, PI-F002          | No               | Covered by both families                           |
| Merchant/checkout manipulation              | ✓           | PI-F004                   | No               | Covered by synthetic merchant fraud                |
| Payment-page manipulation                   | ✓           | PI-F004                   | No               | Covered by synthetic merchant fraud                |
| Transaction substitution                    | ✓           | PI-F001                   | No               | Covered by instruction manipulation                |
| Mule-directed payments                      | ✓           | PI-F001, PI-F002          | No               | Covered by both families                           |
| Coordinated payment initiation              | ✓           | PI-F001, PI-F002, PI-F004 | No               | Covered by all families                            |
| AI-generated payment communications         | ✓           | PI-F001, PI-F002          | No               | GenAI capability within families                   |
| AI-generated merchant/payment impersonation | ✓           | PI-F004                   | No               | Covered by synthetic merchant fraud                |
| QR code manipulation                        | ✓           | PI-F001                   | No               | Variant of instruction manipulation                |
| Refund/return abuse                         | ✓           | PI-F003                   | Yes              | Distinct family                                    |
| Digital Arrest scams                        | ✓           | PI-F002                   | No               | Covered by APP fraud                               |

## PART 5 – FINAL SUMMARY

Table 1 – FINAL PAYMENT INITIATION ATTACK TAXONOMY

| ID      | Attack Family                                  | Variants                                                                                                      | GenAI Classification | Simulation Type | Primary Stage      | Payment Rails                   | Reason for Distinctness                                                                                                          |
|---------|------------------------------------------------|---------------------------------------------------------------------------------------------------------------|----------------------|-----------------|--------------------|---------------------------------|----------------------------------------------------------------------------------------------------------------------------------|
| PI-F001 | GenAI-Powered Payment Instruction Manipulation | Payment redirection; BEC payment fraud; Invoice fraud; QR code manipulation; Beneficiary substitution         | PASS                 | Agentic         | Payment Initiation | All rails                       | GenAI enables hyper-personalized, multi-channel deception at scale—qualitative leap from generic, detectable payment redirection |
| PI-F002 | GenAI-Powered Authorized Push Payment Fraud    | Investment scams; Romance scams; Impersonation scams; Digital Arrest scams; Purchase scams; Advance fee fraud | PASS                 | Agentic         | Payment Initiation | Bank transfers, UPI, wallets    | GenAI enables deepfake/voice/personalized social engineering at scale—qualitative leap from manual social engineering            |
| PI-F003 | GenAI-Powered Refund / Policy Abuse            | AI-generated fake damage images; AI-generated fake damage videos; Wardrobing                                  | PASS                 | Algorithmic     | Payment Initiation | Card, e-commerce                | GenAI enables photorealistic fake evidence—qualitative leap from crude forgeries and physical damage                             |
| PI-F004 | GenAI-Powered Synthetic Merchant Fraud         | Synthetic merchant storefronts; Fake merchant onboarding; AI-generated merchant websites; Merchant collusion  | PASS                 | Hybrid          | Payment Initiation | Card, wallets, BNPL, e-commerce | GenAI enables professional-grade synthetic merchants at scale—qualitative leap from manual, detectable fake merchants            |

Total: 4 final Payment Initiation attack families

Table 2 – ATTACK × OBSERVABLE SIGNAL MATRIX

| Attack Family | Transaction | Payer | Payee | Merchant | Device | Session | Behavioral | Network | Temporal |
|---------------|-------------|-------|-------|----------|--------|---------|------------|---------|----------|
|---------------|-------------|-------|-------|----------|--------|---------|------------|---------|----------|



| Attack Family                                    | Transaction                                          | Payer                                        | Payee                                                      | Merchant                                                         | Device                   | Session             | Behavioral                                                 | Network                                                    | Temporal                                          |
|--------------------------------------------------|------------------------------------------------------|----------------------------------------------|------------------------------------------------------------|------------------------------------------------------------------|--------------------------|---------------------|------------------------------------------------------------|------------------------------------------------------------|---------------------------------------------------|
| <b>PI-F001: Payment Instruction Manipulation</b> | Beneficiary change; Urgent payment; Amount deviation | Unusual payment behavior                     | New beneficiary; Mule database flag; No prior relationship | Vendor impersonation                                             | Device context           | Session anomalies   | Email tone anomalies; Domain spoofing                      | Mule network connections; Multiple payers same beneficiary | Payment shortly after change; Off-hours           |
| <b>PI-F002: APP Fraud</b>                        | New beneficiary; Large transfer; Multiple payments   | Hesitation; Rapid auth; Phone during session | Mule account; No legitimate relationship                   | Fake investment/platform                                         | Normal (victim device)   | Session anomalies   | Unusual navigation; Coercion signs; Voice stress           | Mule network; Fraud connections                            | Payment after suspicious communication; Off-hours |
| <b>PI-F003: Refund Abuse</b>                     | High refund rate; Claim shortly after delivery       | None (customer is attacker)                  | Original payer                                             | E-commerce merchant                                              | Normal (customer device) | Normal session      | Image artifacts; Inconsistent features; No physical return | Same image artifacts; Same IP across claims                | Unusual refund timing                             |
| <b>PI-F004: Synthetic Merchant Fraud</b>         | High chargeback rate; Unusual patterns               | None                                         | Synthetic merchant                                         | AI-generated website; Inconsistent details; No physical presence | Merchant device          | Merchant onboarding | AI image artifacts; Fabricated docs; AI-generated reviews  | Same IP across merchants; Synthetic identities             | Rapid approval; High volume                       |

Table 3 – ATTACK \* SIMULATION MATRIX

| Attack Family | Synthetic Payers                                   | Synthetic Payees                                        | Synthetic Merchants            | Payment Attributes                              | Synthetic Transactions                                                | Behavioral Events                                                  | Network                                   | Simulation Type |
|---------------|----------------------------------------------------|---------------------------------------------------------|--------------------------------|-------------------------------------------------|-----------------------------------------------------------------------|--------------------------------------------------------------------|-------------------------------------------|-----------------|
| PI-F001       | Corporate finance personas; Individual bill payers | Legitimate vendors; Fraudulent mule accounts            | Vendor personas                | Amount profiles; Urgency flags; Invoice numbers | Historical payments; Beneficiary change; Fraudulent authorization     | Normal behavior → Beneficiary change → Urgent payment              | Payer-vendor history; Mule clustering     | Agentic         |
| PI-F002       | Victim personas; KYC-verified customers            | Attacker-controlled accounts; Fake investment platforms | Fake platforms; Fake stores    | Amount distributions; Beneficiary details       | Historical payments; New beneficiary; Fraudulent authorization        | Normal behavior → Contact → Navigation/hesitation → Urgent payment | Attacker-victim patterns; Mule clustering | Agentic         |
| PI-F003       | Customer personas                                  | Original payer                                          | E-commerce merchants           | Refund amounts; Product categories              | Purchase → Delivery → Fake evidence → Refund claim → Refund processed | Normal purchase → Suspicious refund claim                          | Customer-merchant; Fraud rings            | Algorithmic     |
| PI-F004       | Consumer personas; AI shopping agents              | Synthetic merchant accounts                             | AI-generated merchant profiles | Purchase amounts; Product categories; MCC       | Merchant creation → Onboarding → Purchases → Payments → Chargebacks   | Normal consumer → Purchases → Non-delivery → Disputes              | Merchant-identity; Fraud ecosystem        | Hybrid          |

Table 4 – TAXONOMY DECISIONS

| Candidate                   | Decision        | Reason                                                           |
|-----------------------------|-----------------|------------------------------------------------------------------|
| PI-001 Payment Redirection  | MERGE → PI-F001 | Payment Instruction Manipulation family                          |
| PI-002 BEC – Payment Fraud  | MERGE → PI-F001 | Variant – Executive impersonation leading to payment redirection |
| PI-003 Invoice Fraud        | MERGE → PI-F001 | Variant – Fake invoices leading to payment redirection           |
| PI-004 QR Code Manipulation | MERGE → PI-F001 | Variant – Beneficiary substitution via QR code                   |
| PI-008 APP Fraud            | KEEP → PI-F002  | Distinct family – Payer manipulation                             |
| PI-009 Investment Scams     | MERGE → PI-F002 | Variant – Investment pretext                                     |
| PI-010 Romance Scams        | MERGE → PI-F002 | Variant – Romance pretext                                        |

| Candidate                      | Decision              | Reason                                                          |
|--------------------------------|-----------------------|-----------------------------------------------------------------|
| PI-011 Purchase Scams          | MERGE → PI-F002       | Variant — Purchase pretext                                      |
| PI-012 Advance Fee Fraud       | MERGE → PI-F002       | Variant — Advance fee pretext                                   |
| PI-019 Impersonation Scams     | MERGE → PI-F002       | Variant — Impersonation pretext                                 |
| PI-020 Digital Arrest Scams    | MERGE → PI-F002       | Variant — Law enforcement pretext                               |
| PI-013 Refund Abuse            | KEEP → PI-F003        | Distinct family — Fake evidence for refunds                     |
| PI-015 Merchant Collusion      | KEEP → PI-F004        | Distinct family — Synthetic merchant creation                   |
| PI-005 Card Testing            | DROP                  | GenAI amplification, not transformation; Authentication primary |
| PI-006 Velocity Abuse          | DROP                  | GenAI amplification, not transformation; overlaps with AML      |
| PI-007 Duplicate Payment       | DROP                  | No GenAI load-bearing role; insufficient evidence               |
| PI-014 Real-Time Payment Fraud | DROP                  | GenAI amplification; rail-specific; insufficient evidence       |
| PI-016 UPI Collect Request     | DROP                  | Feature discontinued; no GenAI transformation                   |
| PI-017 Fake UPI Apps           | MOVE → Authentication | Primary attack is credential theft                              |
| PI-018 Remote Access Fraud     | MOVE → Device/Session | Primary attack is device compromise (RAT)                       |

FINAL SUMMARY METRICS

| Metric                                                                     | Value                                                                                                                                                                                                                                                                             |
|----------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Total final attack families                                                | 4                                                                                                                                                                                                                                                                                 |
| Total variants                                                             | 16 (across 4 families)                                                                                                                                                                                                                                                            |
| Important candidates merged                                                | PI-001, PI-002, PI-003, PI-004 → PI-F001; PI-009, PI-010, PI-011, PI-012, PI-019, PI-020 → PI-F002                                                                                                                                                                                |
| Important candidates moved                                                 | PI-017 → Authentication; PI-018 → Device/Session                                                                                                                                                                                                                                  |
| Important candidates dropped                                               | PI-005 (Card Testing); PI-006 (Velocity Abuse); PI-007 (Duplicate Payment); PI-014 (Real-Time Payment Fraud); PI-016 (UPI Collect Request)                                                                                                                                        |
| Theoretical/future threats                                                 | None identified with sufficient evidence for inclusion                                                                                                                                                                                                                            |
| Remaining research gaps                                                    | Real-world frequency of AI-generated fake damage images in refund fraud; specific detection evasion effectiveness against production fraud systems; impact of emerging GenAI architectures on detection accuracy; prevalence of synthetic merchant fraud in live payment networks |
| Payment rails/channels covered                                             | All rails — cards, UPI, bank transfers, wallets, instant payments, e-commerce, P2P, BNPL                                                                                                                                                                                          |
| Important Payment Initiation surfaces not represented as separate families | Card testing (dropped — GenAI amplification not transformation); Velocity abuse (dropped — overlaps with AML); Real-time payment fraud (dropped — rail-specific amplification)                                                                                                    |

FINAL NOTE ON TAXONOMY CONSISTENCY

The Payment Initiation taxonomy has **4 families**, emerging naturally from the evidence and the HARD GenAI Removal Test — not forced. This is consistent with:

| Stage                       | Families |
|-----------------------------|----------|
| Identity/KYC                | 5        |
| Account Creation/Onboarding | 3        |
| Device/Session              | 5        |
| Authentication              | 4        |
| Payment Initiation          | 4        |

Each of the 4 Payment Initiation families represents a **distinct attack mechanism** with **load-bearing GenAI transformation**, **strong evidence**, and **simulation feasibility**.

**The unifying theme across all 4 Payment Initiation families** is the shift from **"detectable deception" to "indistinguishable generation"** – fraudsters no longer rely on generic scripts, manual forgeries, limited-scale social engineering, or detectable fake merchants; they use GenAI to generate perfect deception at scale, in real-time, across multiple channels, making the fraudulent payment instruction indistinguishable from legitimate ones until it's too late.